

ZADANIE 1: Baseline Konfiguracji Stacji Roboczej Windows 11

Informacje podstawowe

- **Wersja:** 1.0
 - **Zakres:** Wszystkie stacje robocze Windows 11 w środowisku firmowym
 - **Metoda weryfikacji:** Audyt GPO + skrypt PowerShell
-

1. Polityka haseł i uwierzytelniania

Wymaganie	Wartość	Test
Minimalna długość hasła	12 znaków	GPO: Computer Configuration → Windows Settings → Security Settings → Account Policies
Złożoność hasła	Włączona (wielkie, małe, cyfry, znaki specjalne)	Password must meet complexity requirements = Enabled
Historia haseł	5 ostatnich haseł	Enforce password history = 5
Maksymalny wiek hasła	90 dni	Maximum password age = 90
Blokada konta	5 nieudanych prób / 30 min blokady	Account lockout threshold = 5, Account lockout duration = 30
Windows Hello for Business	Wymagane dla wszystkich użytkowników	WHfB GPO = Enabled
MFA	Obowiązkowe przy zdalnym dostępie	Conditional Access Policy verification

2. Konta systemowe

Konta lokalne

- **Administrator lokalny:** Zmieniona nazwa, wyłączony (włączany tylko przez LAPS)
- **Guest:** Wyłączone
- **LAPS:** Wdrożone na wszystkich stacjach (rotacja hasła co 30 dni)

Konta domenowe

- **Użytkownicy standardowi (Biuro, Remote):** Brak uprawnień lokalnego administratora
- **IT (3 osoby):** Osobne konta z uprawnieniami admin (format: admin_imie)
- **Management (4 osoby):** Standardowe uprawnienia + BitLocker recovery dostęp

Test: `Get-LocalUser` | `Select Name, Enabled` + weryfikacja członkostwa w grupach

3. Zainstalowane aplikacje

MUSZĄ BYĆ:

- Antywirus (Microsoft Defender + EDR)
- VPN Client (firmowy)
- Backup agent
- Monitoring agent (dla SIEM)
- Office 365
- Przeglądarki: Edge (główna), Chrome/Firefox (opcjonalnie)

NIE MOGĄ BYĆ:

- TeamViewer, AnyDesk (poza zatwierdzonymi przez IT)
- P2P (BitTorrent, eMule)
- Cracking tools
- Personal cloud sync (Dropbox, Google Drive osobiste)

Test: Skrypt PowerShell sprawdzający `Get-Package` + lista zatwierdzonych aplikacji w GPO (AppLocker)

4. Konfiguracja systemu

Kontrola	Ustawienie	Weryfikacja
Windows Updates	Automatyczne, wymuszone co 7 dni	GPO: Configure Automatic Updates = 4
BitLocker	Włączony (wszystkie dyski, TPM + PIN)	<code>manage-bde -status</code>
Windows Firewall	Włączony (wszystkie profile)	<code>Get-NetFirewallProfile</code>

UAC	Maksymalny poziom	GPO: User Account Control settings
SMBv1	Wyłączony	<code>Get-WindowsOptionalFeature -Online -FeatureName SMB1Protocol</code>
PowerShell Logging	Włączony (module + script block)	GPO: Administrative Templates → Windows Components → Windows PowerShell
RDP	Wyłączony (wyjątek: IT po zgłoszeniu)	GPO: Allow users to connect remotely = Disabled
AutoRun	Wyłączony	Registry: NoDriveTypeAutoRun = 255

5. Dodatkowe zabezpieczenia

- **Attack Surface Reduction (ASR):** 10 podstawowych reguł włączonych w trybie Block
- **Credential Guard:** Włączony
- **Exploit Protection:** Domyślne ustawienia Windows Defender
- **Network Protection:** Włączona
- **Screen lock:** Automatyczny po 10 min bezczynności

Test: `Get-MpPreference + Get-ProcessMitigation -System`

Metoda weryfikacji kompleksowej

powershell

Skrypt baseline-check.ps1 zwraca PASS/FAIL dla każdej kontroli

Uruchomienie: `.\baseline-check.ps1 | Export-Csv -Path wyniki.csv`